

ACTIVIDAD 01 - ANÁLISIS Y PLANIFICACIÓN DEL PENTEST

HACKER WOMEN COUNCIL - ETHICAL HACKER

NOMBRE: MARÍA TERESA MEDINA

FECHA: 31/08/2026



1. OBJETIVOS

- ① CONOCER QUE TAN EXPUESTA ESTÁ LA APLICACIÓN Y QUE TAN LEJOS PODRÍA LLEGAR UN ATACANTE CON LA INFORMACIÓN DISPONIBLE
- ② ENCONTRAR VULNERABILIDADES DENTRO DE LA APLICACIÓN QUE PUEDAN COMPROMETER LA SEGURIDAD DE DATOS DE LOS CLIENTES
- ③ SABER SI ES POSIBLE QUE UN USUARIO NORMAL PUEDA ESCALAR PRIVILEGIOS Y ACCEDER A FUNCIONES ADMINISTRATIVAS



2. ALCANCE

SI SE EVALUARÁ

- APLICACIÓN WEB
- BASE DE DATOS
- MECANISMOS DE AUTENTICACIÓN

FUERA DE ALCANCE

- REDES SOCIALES DE LA EMPRESA
- EQUIPOS DE EMPLEADOS
- CUENTAS DE CORREO
- PROVEEDORES EXTERNOS
- OTROS SISTEMAS



3. AUTORIZACIÓN Y CONDICIONES

PERMISOS REQUERIDOS

- CREDENCIALES DE ACCESO
- HORARIOS DE LAS PRUEBAS

CONDICIONES ACORDADAS

- LAS PRUEBAS DEBEN REALIZARSE EN LOS HORARIOS DE MENOR ACTIVIDAD
- NO ESTÁ PERMITIDO REALIZAR ACCIONES QUE PUEDAN INTERRUPTIR EL FUNCIONAMIENTO DE LA PLATAFORMA
- NO ESTÁ PERMITIDO REALIZAR ACCIONES QUE AFECTEN LA INFORMACIÓN REAL DE LOS CLIENTES

4. TIPO DE PENTEST

GRAY-BOX



JUSTIFICACIÓN

INFORMACIÓN PARCIAL DE LA INFRAESTRUCTURA:

- * APLICACIÓN WEB
- * BASE DE DATOS
- * MECANISMOS DE AUTENTICACIÓN



5. PLANIFICACIÓN

OBJETIVOS

REVISAR LOS PRINCIPALES RIESGOS EVALUADOS SEGUN LA OWASP TOP 10

ALCANCE

PROHIBIDO MODIFICAR, ELIMINAR O CORROMPER DATOS DE USUARIOS REALES

PROHIBIDO ATAQUES DE DENEGACIÓN DE SERVICIO

PERMISOS Y CONDICIONES

- FIRMA DE ACUERDOS LEGALES
- ENTREGA DE ACTIVOS (CREDENCIALES DE USUARIO)

METODOLOGIA A UTILIZAR

OWASP

RECOPIACION DE INFORMACION PREVIA

RECOLECCIÓN DE INFORMACIÓN MEDIANTE MOTORES DE BUSQUEDA Y REVISIÓN DE METADATOS EN ARCHIVOS PÚBLICO

RECURSOS NECESARIOS

OWASP WEB APPLICATION SECURITY TESTING

https://github.com/OWASP/wstg/tree/master/document/4-Web_Application_Security_Testing

PROGRAMACION DEL PENTEST

LAS PRUEBAS SE EJECUTARAN DURANTE LAS HORAS DE MENOR TRAFICO DE USUARIOS 00:00 A 05:00



6.FASES DEL PENTEST

RECONOCIMIENTO

RECOLECCIÓN DE INFORMACIÓN MEDIANTE MOTORES DE BUSQUEDA Y REVISIÓN DE METADATOS EN ARCHIVOS PÚBLICO

DETERMINAR LA VERSIÓN DEL SERVIDOR Y RESPUESTAS DEL SERVIDOR QUE DETALLEN LA ARQUITECTURA INTERNA

INSPECCIÓN DEL CÓDIGO FUENTE DEL LADO DEL CLIENTE (HTML, JAVASCRIPT, CSS).

IDENTIFICACIÓN DE RUTAS RELATIVAS DE API INTERNAS, CREDENCIALES DE PRUEBA O LÓGICA DE NEGOCIO EXPUESTA EN SCRIPTS JS.

ANÁLISIS DE VULNERABILIDADES

SEGUN LA VERSION DEL SERVIDOR, BUSCAR VULNERABILIDADES CONOCIDAS (CVE)

VERIFICACIÓN DE MÉTODOS HTTP INSEGUROS HABILITADOS EN EL SERVIDOR (COMO TRACE, PUT, DELETE O CONNECT).

DETERMINACIÓN DE LOS DISTINTOS ROLES DEL SISTEMA (ADMINISTRADOR, USUARIO ESTÁNDAR, AUDITOR, ETC.) Y LOS PRIVILEGIOS TEÓRICOS ASIGNADOS A CADA UNO.

ANÁLISIS DE CÓMO SE CREAN, ASIGNAN Y ELIMINAN LAS CUENTAS DENTRO DE LA INFRAESTRUCTURA INTERNA.

EXPLOTACIÓN

PRUEBAS DE INYECCIÓN Y VALIDACIÓN DE ENTRADAS:

INYECCIÓN DE CÓDIGO / COMANDOS
INYECCIÓN SQL / NOSQL
CROSS-SITE SCRIPTING - XSS

POST EXPLOTACIÓN

MANIPULACIÓN DE OBJETOS Y RUTAS:
MODIFICACIÓN DE IDENTIFICADORES (/API/USER/101 A /API/USER/102) PARA ACCEDER O AREGISTROS DE OTROS USUARIOS SIN PERMISO.

INTENTO DE EJECUCIÓN DE FUNCIONES ADMINISTRATIVAS ACTUANDO DESDE UN ROL DE USUARIO CON MENORES PRIVILEGIOS.

BYPASS DE CONTROLES DE ACCESO MANIPULANDO LA ESTRUCTURA DE PETICIONES.

INFORME

RESUMEN EJECUTIVO CON ALCANCE DE LAS PRUEBAS, POSTURA GLOBAL DE RIESGOS Y EVALUACIÓN CUALITATIVA GENERAL (EJ. ALTO, MEDIO, BAJO).

TOP 3-5 VULNERABILIDADES CRÍTICAS: DESCRIPCIÓN BREVE DE LOS HALLAZGOS QUE REPRESENTAN UN IMPACTO FINANCIERO, OPERATIVO O REPUTACIONAL DIRECTO.

METODOLOGÍA Y COBERTURA DE PRUEBAS ((OWASP WSTG V4.2 / V5).

MAPA DE COBERTURA INDICANDO QUÉ CATEGORÍAS FUERON EVALUADAS (WSTG-INFO, WSTG-CONF, WSTG-INPV, ETC.).

INFORME TÉCNICO CON: CADA VULNERABILIDAD IDENTIFICADA, CLASIFICACIÓN DEL RIESGO (VECTOR CVSS), DESCRIPCIÓN TÉCNICA Y RECOMENDACIÓN DE REMEDIACIÓN



7. INVESTIGACIÓN

METODOLOGÍA ELEGIDA

OWASP

POR QUÉ SERÍA ÚTIL PARA ESTE PROYECTO?

PORQUE PROPORCIONA TODO EL ESQUEMA PARA REALIZAR LAS PRUEBAS DE PENETRACIÓN A LA APLICACION WEB DESPUES DE HABER SIDO IMPLEMENTADA Y GARANTIZAR QUE NO SE HAYA PASADO NADA POR ALTO